hochschule burgenland
University of Applied Sciences

IT-Governance als Einflussfaktor der Verwendung von Multifaktor-Authentifizierung in beruflichen und privaten Kontexten

Seminararbeit

Department Informationstechnologie

Von
– Name –
23104

Kurs gehalten von:
–Lehrer–

Department –Department–:
–Studiengang–
Datum: 3. März 2026

Inhaltsverzeichnis

1 Aufgabenstellung 2

2 Einleitung 2
2.1 Problemstellung . . . 2
2.2 Zielsetzung und wissenschaftliche Fragestellung . . . 3

3 Grundlagen 4
3.1 Allgemeine Definitionen . . . 4
3.2 Historische Entwicklung – von 1FA zu MFA . . . 5
3.3 Relevante Protokolle und Technologien . . . 6
3.3.1 Authentifizierung & Autorisierung . . . 6
3.3.2 Endgeräte . . . 7
3.4 MFA und Regulatorik . . . 8
3.5 Verwendungskontext und Akzeptanz . . . 9

4 Forschungsstand 10
4.1 Herausforderungen . . . 10
4.1.1 MFA als technische Herausforderung . . . 10
4.1.2 MFA als Herausforderung an Nutzer:innen . . . 11
4.1.3 MFA als IT-Governance-Herausforderung . . . 11
4.2 Wirkmechanismen der Nutzung von MFA . . . 12
4.3 IT-Governance als Treiber der Akzeptanz und Nutzung von Multifaktor-Authentifizierung 13
4.4 Beantwortung der Forschungsfrage . . . 14

5 Forschungsmethodik 15
5.1 Forschungsdesign und wissenschaftstheoretische Einordnung . . . 15
5.2 Grundgesamtheit und Stichprobenziehung . . . 15
5.3 Datenerhebung und Instrumente . . . 16
5.3.1 Fragebogenkonstruktion . . . 16
5.3.2 Operationalisierung der Variablen . . . 16
5.3.3 Pre-Test . . . 17
5.4 Datenaufbereitung und Auswertungsverfahren . . . 17
5.4.1 Data Preprocessing (Datenbereinigung) . . . 17
5.4.2 Deskriptive und Inferenzstatistische Analyse . . . 17
5.5 Ethische Überlegungen . . . 18

6 Zusammenfassung 18

7 Zusammenfassung 19

8 Anhang 20

1 Aufgabenstellung

Kurzfassung Digitale Authentifizierungstechnologien befinden sich in einem strategischen Spannungsfeld zwischen Sicherheit und Usability, welches in der vorliegenden Seminararbeit vorgestellt und diskutiert werden soll. Diese Vielschichtigkeit stellt Unternehmen und Personen vor die Herausforderung, wie sie sensible Daten und Zugriffe darauf nachhaltig sichern können. Ein-Faktor-Authentifizierung kann dieses Problem nicht (mehr) lösen, da dieser Faktor häufig ein singuläres Passwort ist, dessen Anfälligkeit für Manipulation umfangreich dokumentiert wurde (Joseph Bonneau et al., 2015, S. 81-82). Gleichzeitig verzeichnen mehrere europäische Organisationen einen starken Anstieg von identitätsbezogenen Angriffen gegen Einzelpersonen und Unternehmen (European Union Agency for Cybersecurity., 2024, S. 27). Multi-Faktor-Authentifizierung schließt diese Lücke, indem wie im Namen ersichtlich, unterschiedliche zusätzliche Faktoren Teil der Identitätsfeststellung werden (Lawrence O'Gorman und O'Gorman, 2003, S. 2022-2024). Weiters nehmen die Bedrohungen im Internet zu. Angriffsvektoren wie Phishing, Identitätsbetrug und Malware bedrohen Privatpersonen und Unternehmen gleichermaßen. Ein-Faktor-Authentifizierungssysteme stellen in diesem Zusammenhang ein großes Risiko dar, weil sie leicht umgangen werden können, und vor allem in Form von Passworten anfällig sind für menschliche Faktoren, wie Bequemlichkeit oder Vergesslichkeit (Das et al., 2020, S. 5446). Insbesondere sensible Bereiche wie das Gesundheitswesen, Banken sowie die öffentlichen Verwaltung müssten mit großen Folgen einer Kompromittierung der Daten rechnen, weshalb Guidelines und Standards dringend notwendig sind (EBA publishes an Opinion on the elements of strong customer authentication under PSD2 | European Banking Authority, o. J., S. 12). Dieser wissenschaftliche Text soll untersuchen, welche Faktoren auf die Verwendung von MFA-Technologien einwirken. Dabei liegt der Fokus nur teilweise auf den Bereich Usability und Akzeptanz der Technologie, sondern vorwiegend auf dem Bereich Governance als Einflussfaktor. Dieser wird vor allem in Hinblick auf die wachsende Menge an IT-Regularien und Governance-Anforderungen in unterschiedlichen Kontexten zunehmend auch für Privatpersonen beziehungsweise in privaten Kontexten relevant.

2 Einleitung

2.1 Problemstellung

Digitale Authentifizierungstechnologien bewegen sich in einem strategischen Spannungsfeld zwischen Sicherheit und Usability. Diese Dualität stellt Unternehmen wie Privatpersonen vor die Herausforderung, sensible Daten und Zugriffe nachhaltig zu sichern. Die klassische Ein-Faktor-Authentifizierung (1FA) kann dieses Problem nicht mehr lösen, da der Faktor „Wissen" (meist ein Passwort) durch menschliche Schwächen wie Vergesslichkeit oder Bequemlichkeit anfällig ist und dessen Manipulierbarkeit in der Literatur umfangreich dokumentiert wurde (Bonneau et al., 2015, S. 81).

Gleichzeitig verzeichnen europäische Organisationen einen massiven Anstieg von iden-

titätsbezogenen Angriffen (European Union Agency for Cybersecurity, 2024, S. 27). Angriffsvektoren wie Phishing, Identitätsbetrug und Malware bedrohen dabei private und korporative Akteure gleichermaßen. In diesem Kontext stellt die alleinige Nutzung von Passwörtern ein inakzeptables Risiko dar (Das et al., 2020, S. 5446).

Multifaktor-Authentifizierung (MFA) schließt diese Sicherheitslücke, indem sie zusätzliche, voneinander unabhängige Faktoren in die Identitätsfeststellung integriert (O'Gorman, 2003, S. 2023). Insbesondere in sensiblen Sektoren wie dem Gesundheitswesen, dem Bankensektor oder der öffentlichen Verwaltung hätte eine Kompromittierung verheerende Folgen, weshalb verbindliche Standards und Guidelines hier dringend erforderlich sind (EBA, o. J., S. 12).

Die vorliegende Arbeit untersucht, welche Faktoren die effektive Nutzung von MFA beeinflussen. Während Aspekte der Usability und Akzeptanz als Rahmenbedingungen betrachtet werden, liegt der primäre Fokus auf IT-Governance als steuerndem Element. Obwohl Governance üblicherweise im Unternehmenskontext verortet wird, gewinnt sie durch die wachsende Anzahl an IT-Regularien (NIS-2, DORA, FIDA, CRA) zunehmend auch für Privatpersonen an Relevanz, da berufliche Sicherheitsvorgaben und private Nutzungsgewohnheiten zunehmend verschwimmen.

2.2 Zielsetzung und wissenschaftliche Fragestellung

Multifaktor-Authentifizierung (MFA) stellt weit mehr dar als eine rein technische Standardlösung für das Identitäts- und Zugangsmanagement. Sie bewegt sich in einem komplexen Anforderungsfeld: Die Technologie muss nicht nur kryptografisch sicher und resistent gegen Täuschung sein, sondern gleichzeitig externe Compliance-Anforderungen erfüllen und durch eine hohe Benutzerfreundlichkeit (Usability) Risiken minimieren, die durch menschliches Fehlverhalten entstehen (Kim et al., 2011, S. 187).

In diesem Kontext nimmt IT-Governance eine Schlüsselrolle ein. Durch Richtlinien und strategische Vorgaben können Unternehmen Sicherheitsaspekte mit den Interessen der Stakeholder in Einklang bringen (Wibowo & Ramli, 2022, S. 2). Auf Basis der ermittelten Authenticator Assurance Levels (AAL) werden Technologien und Prozesse definiert, um diese Ziele zu erreichen. Damit verortet sich das Thema nachvollziehbar im Bereich des strategischen IT-Infrastruktur-Managements.

Daraus abgeleitet lautet die zentrale Forschungsfrage der vorliegenden Arbeit:

> *Inwiefern fungiert IT-Governance als Einflussfaktor auf die Verwendung von Multifaktor-Authentifizierung in beruflichen und privaten Kontexten?*

Um diese Fragestellung zielgerichtet zu beantworten und die Zusammenhänge empirisch messbar zu machen, werden folgende Hypothesen aufgestellt und im Rahmen der Arbeit quantitativ geprüft:

- H_0**:** Die berufliche Verwendung von MFA hat keine Auswirkungen auf die private Verwendung.

- H_1**:** Eine etablierte IT-Governance im beruflichen Kontext wirkt sich positiv auf die Nutzung und Akzeptanz von Multi-Faktor-Authentifizierung aus.
- H_2**:** Eine hohe Benutzerfreundlichkeit von MFA-Systemen erhöht die Akzeptanz sowohl im beruflichen als auch im privaten Kontext.
- H_3**:** Positive Erfahrungen mit MFA im beruflichen Kontext erhöhen die Wahrscheinlichkeit der privaten Nutzung von MFA (Spill-over-Effekt).

Methodisch stützt sich die vorliegende Arbeit auf ein zweistufiges Forschungsdesign. Den theoretischen Unterbau bildet eine systematische Literaturrecherche (Literature Review), bei der relevante wissenschaftliche Publikationen, Fachartikel und Standards (z. B. NIST, ISO) analysiert werden, um sowohl die technischen Aspekte von MFA als auch die organisatorischen Governance-Faktoren zu beleuchten. Darauf aufbauend erfolgt zur Überprüfung der aufgestellten Hypothesen eine quantitative Primärdatenerhebung in Form einer standardisierten Online-Umfrage. Dieses Vorgehen ermöglicht es, die Nutzungsmuster im beruflichen und privaten Kontext empirisch gegenüberzustellen, den Spill-over-Effekt statistisch zu quantifizieren sowie Erfolgsfaktoren und Hindernisse zu identifizieren.

Die Relevanz dieser Arbeit ergibt sich insbesondere für (angehende) IT-Manager:innen sowie Verantwortliche im Bereich Identity- und Access-Management (IAM), um Entscheidungen mit stärkerem Nutzer:innen-Fokus zu treffen und Organisationen auf die steigende Dichte an regulatorischen Vorgaben vorzubereiten.

3 Grundlagen

3.1 Allgemeine Definitionen

Authentifizierung bezeichnet den technischen Prozess, bei dem ein System die behauptete, digitale Identität einer Person prüft. Dabei ist sie von Identitätsfeststellung (Identity Proofing) und Autorisierung zu unterscheiden (Temoshok et al., 2025a–c).

Klassisch erfolgte Authentifizierung mittels eines Faktors, über Wissen (zum Beispiel Passwort). Angesichts bekannter Schwächen von Passwörtern und darauf abgestimmter Angriffsformen empfiehlt der NIST-Rahmen abhängig vom Risiko der Anwendung höhere Authenticator Assurance Levels (AAL) bis hin zu verpflichtender Multifaktor-Authentifizierung (MFA) (Temoshok, 2025; Temoshok et al., 2025b).

MFA kombiniert mindestens zwei unabhängige Faktorarten (O'Gorman & O'Gorman, 2003, S. 2022):

- **Besitz** („Something you have“): Smartcard, Hardware-Schlüssel, Token.
- **Inhärenz** („Something you are“): biometrische Merkmale (zum Beispiel Fingerabdruck, Gesichtsscan).
- **Wissen** („Something you know“): Passwort, PIN, Sicherheitsfragen.

Neue Darstellungen erweitern diese drei klassischen Faktoren um zwei weitere:

- **Ortsbezug** („Somewhere you are“): IP-Adresse, Geolocation.
- **Tätigkeitsbezug** („Something you do“): Verhalten mit dem Gerät, Klick- und Tippverhalten (OWASP, o. J.).

Für den vorliegenden Text liegt der Fokus jedoch auf den obengenannten Faktoren. Einerseits aufgrund ihrer dichteren Forschungslage, andererseits um Kreuzbeziehungen (zum Beispiel: Wie wirkt Unternehmensgovernance auf den Arbeitsort und die IP-Adresse bei Home-Office-Regelungen?) zu reduzieren, die hier nicht in der gebührenden Komplexität dargestellt werden könnten.

Zur Absicherung digitaler Identitäten wird eine Kombination mehrerer etablierter Protokolle und Technologien verwendet, um sowohl die Identitätsprüfung als auch die Zugriffssteuerung zu regeln (Rose et al., 2020, S. 6). Auf diese wird in Folge genauer eingegangen.

Während traditionelle Modelle oft auf örtlichen (sogenannten perimeterbasierten) Ansätzen beruhten, erfordern moderne Architekturen eine kleinteilige Unterscheidung zwischen der Verifizierung einer Identität (Authentifizierung) und der Gewährung von Zugriffsrechten (Autorisierung) (Shirey, 2007, S. 25–28).

Entscheidend ist die Unabhängigkeit der Faktoren voneinander, aber auch ihre Bindung an die Nutzer:in und das verwendete Protokoll (zum Beispiel bei einem kryptografischen Herausforderungs-Antwort-Verfahren). Damit steigt die Resistenz gegen Phishing oder technische Manipulation, wie etwa bei FIDO2/WebAuthn als besitzbasierten, kryptografischen Faktoren (Lang et al., 2016, S. 423).

In risikobasierten Ansätzen (RBA) werden zusätzliche Faktoren bei auffälligem Kontext angefordert (Wiefling et al., 2019). Allerdings sind sie im Hinblick auf die Anfälligkeit von Passwörtern durchaus auch unter anderen Umständen zu empfehlen (Otta et al., 2023, S. 4).

3.2 Historische Entwicklung – von 1FA zu MFA

„In times gone by, authentication was not a complex task. One person, call her Alice, would meet another person, Bob, and either recognize him by visual appearance or not. [. . .] Now we cannot ‘see’ the entity on the remote end of a computer network, and indeed the entity could be a friend, a machine, or an attacker. We exchange personal information, such as financial and health data, that we wish to remain as private and as confidential as correspondence between spies.“ (O’Gorman, 2003, S. 2001)

Die Entwicklung der digitalen Authentifizierung ist eng mit der allgemeinen Informationssicherheit verbunden. Schon in den 1960er-Jahren wurden Passwörter als primäre Methode zur Zugangskontrolle eingeführt und über Jahrzehnte als Standard eingesetzt (Bonneau et al., 2015, S. 78–80). Dieses Prinzip geht von der Annahme aus, dass nur autorisierte Personen das zugrunde liegende „Geheimnis“ kennen (O’Gorman & O’Gorman, 2003, S. 2022).

Mit der zunehmenden Vernetzung und Komplexität moderner IT-Systeme steigen allerdings die Sicherheitsrisiken sukzessiv. Das beeinflusst nur teilweise die Sensibilisierung von

Nutzer:innen bezüglich IT-Risiken: Empirische Studien zeigen, dass Nutzer:innen häufig dieselben oder sehr einfache Passwörter für mehrere Dienste wiederverwenden, um die kognitive Belastung zu reduzieren (Florêncio et al., 2007, S. 660). Dieser menschliche Faktor führt zu einer hohen Anfälligkeit für Angriffe wie Credential Stuffing (Kunke et al., 2021, S. 59) und erleichtert Brute-Force-Angriffe (Bonneau et al., 2012, S. 555).

Als Reaktion auf diese Schwachstelle entstanden Zwei-Faktor-Authentifizierungsverfahren (2FA), die erstmals Besitzfaktoren wie Hardware-Token oder mobile TAN-Generatoren einbezogen. Der Übergang zur Mehrfaktor-Authentifizierung (MFA) erfolgte evolutionär, indem biometrische und kontextbezogene Merkmale ergänzt wurden (Temoshok et al., 2025, S. 14).

Aktuelle Authentifizierungssysteme vereinen technische Innovationen mit Anforderungen an Datenschutz, Benutzerfreundlichkeit und regulatorische Vorgaben, etwa im Finanzwesen durch die Zahlungsdienst-Richtlinie PSD2 (de Bruijn & Janssen, 2017, S. 3). Damit bildet MFA heute einen zentralen Bestandteil moderner Sicherheitsarchitekturen, der technologische sowie auch organisatorische Aspekte vereint.

Aktuelle Multi-Faktor-Authentifizierungssysteme (MFA) nutzen eine Vielzahl technischer Verfahren, die sich (unter anderem) im Sicherheitsniveau, hinsichtlich ihrer Benutzerfreundlichkeit und im Implementierungsaufwand unterscheiden (Mohammed et al., 2023, S. 4).

Die Verbindung mehrerer Faktoren erhöht die Resilienz gegenüber unbefugten Zugriffen, da Angreifer:innen nicht mehr nur ein einzelnes Geheimnis kompromittieren müssen. Dabei ist die erwähnte Unabhängigkeit der Faktoren und Bindung der Faktoren an Gerät und Nutzer:in entscheidend, wie sie in den Digital Identity Guidelines des NIST definiert sind (Temoshok et al., 2025, S. 12–14). Zu diesem Zweck werden im Folgenden relevante Technologien und Protokolle kurz vorgestellt.

3.3 Relevante Protokolle und Technologien

3.3.1 Authentifizierung & Autorisierung

Die Authentifizierung ist der Prozess, bei dem ein Anspruchsteller (Claimant) den Besitz und die Kontrolle über einen oder mehrere Authentifikatoren nachweist, um seine Identität gegenüber einem Bestätiger (Verifier) zu bestätigen (Temoshok et al., 2025, S. 4–5). Authentifizierungsmethoden basieren traditionell, wie einleitend erwähnt, auf drei Faktoren (NIST SP 800-63 Digital Identity Guidelines, o. J.).

Da simple Passwörter anfällig für Diebstahl und Phishing sind, gilt die MFA als Standard für höhere Sicherheitsanforderungen. MFA kombiniert mindestens zwei verschiedene dieser Faktoren, um die Sicherheit über die bloße Kenntnis eines Geheimnisses hinaus zu erhöhen; also zu Authentifizieren (Ometov et al., 2018, S. 3).

Einmalpasswörter (One-Time Password, OTP) beruhen auf kurzlebigen Codes, die entweder zeit- (Time-Based One-Time Password, TOTP) oder zählerbasiert (HMAC-based One-Time Password, HOTP) generiert werden (M'Raihi et al., 2011, S. 3–4).

Wird der Code per App oder Hardware-Token erzeugt, gilt das Verfahren als relativ sicher (O'Gorman, 2003). SMS-basierte Übermittlungen sind hingegen anfällig für Phishing und

SIM-Swapping-Angriffe (Ulqinaku et al., 2020, S. 1200–1201).

Hardware-Token und Smartcards stellen physische Besitzfaktoren dar, die über kryptografische Verfahren (beispielsweise U2F, FIDO2) eine Challenge-Response-Authentifizierung ermöglichen. Diese Lösungen gelten als besonders resistent gegen Phishing und Replay-Angriffe (Lang et al., 2016, S. 424–427), erfordern jedoch organisatorischen Aufwand bei Verwaltung und Einsatz (Pfeffer et al., 2021, S. 40–42).

Biometrische Authentifizierung nutzt inhärente Merkmale wie Fingerabdruck, Gesicht oder Stimme. Sie bietet leichte Nutzung, wirft aber Fragen zum Datenschutz, zur Einwilligung und zu möglichen Spoofing-Risiken auf (Trewin et al., 2012, S. 160–163; Wolf et al., 2019, S. 151).

Ein zentraler Standard für Authentifizierung ist FIDO2, der vom W3C und der FIDO-Alliance entwickelt wurde. Er besteht aus der Web Authentication API (WebAuthn) und dem Client-to-Authenticator-Protocol (CTAP). FIDO2 ermöglicht passwortlose Authentifizierung durch asymmetrische Kryptographie, bei der private Schlüssel sicher auf einem Authentifikator (zum Beispiel YubiKey oder Smartphone-TPM) gespeichert werden und den Servern nur der öffentliche Schlüssel bekannt ist (Lyastani et al., 2020, S. 269).

Zur Klassifizierung der Stärke von Authentifizierungsprozessen definiert das NIST Authentication Assurance Levels (AAL). AAL1 erfordert einfache Authentifizierung, AAL2 verlangt MFA mit zwei Faktoren, und AAL3 setzt den Einsatz kryptografischer Hardware-Token voraus, die resistent gegen Verifier-Impersonation (Phishing) sind (Temoshok et al., 2025, S. 13–14).

Nach einer erfolgreichen Authentifizierung regelt die Autorisierung, auf welche Ressourcen zugegriffen werden kann, also welcher Account auf welche Art autorisiert ist. In modernen IT-Architekturen erfolgt dies oft dynamisch und kontextbezogen (Rose et al., 2020, S. 6).

Häufig genutzte Modelle sind Role-Based Access Control (RBAC), bei welchem Rechte an Rollen gebunden sind, sowie Attribute-Based Access Control (ABAC), das Entscheidungen basierend auf Attributen der Nutzenden und der Umgebung trifft (Hu et al., 2014, S. 4).

Im Rahmen von Zero Trust und modernen Sicherheits-Frameworks wird das Prinzip der minimalen Rechtevergabe (Least Privilege Access) durchgesetzt. Dies kann durch Just-In-Time (JIT) Zugriff erweitert werden, bei dem Privilegien nur temporär für einen spezifischen Zeitraum oder eine Aufgabe gewährt werden (Rose et al., 2020, S. 12).

In zentral verwalteten Umgebungen (zum Beispiel Single Sign-On in einem Unternehmen) überträgt ein Identity Provider (IdP) Autorisierungsinformationen mittels Assertions (zum Beispiel via SAML oder OIDC) an die Relying Party (RP). Das NIST definiert hierfür Federation Assurance Levels (FAL), die festlegen, wie stark die Assertion gegen Manipulation und Injektionsangriffe geschützt ist (Temoshok et al., 2025, S. 40–44).

3.3.2 Endgeräte

Die Sicherheit des Endgeräts spielt eine entscheidende Rolle bei der Autorisierungsentscheidung, da selbst eine valide Benutzeridentität auf einem kompromittierten Gerät ein Risiko

darstellt.

Technologien zur Autorisierung unterscheiden zwischen Plattform Authenticators (im Endgerät integriert, zum Beispiel Apple Touch ID, Windows Hello), die oft biometrische Faktoren nutzen, und Roaming Authenticators (zum Beispiel YubiKeys), die zwischen Geräten gewechselt werden können. Die Nutzung integrierter Plattform-Authentifikatoren bindet den Zugriff stark an das spezifische Endgerät.

Authenticator-Apps wie Google Authenticator oder Microsoft Authenticator implementieren typischerweise das TOTP-Verfahren (wie definiert in RFC 6238 (M'Raihi et al., 2011)). Sie sind von Mobilfunknetzen unabhängig und bieten dadurch ein höheres Sicherheitsniveau bei geringem Bedienaufwand (Temoshok et al., 2025, §4, S. 13).

In einer Zero-Trust-Architektur wird keinem Gerät implizit vertraut (Rose et al., 2020, S. 11). Der Sicherheitsstatus (Device Posture), zum Beispiel Patch-Level, Malware-Freiheit oder Standort, wird kontinuierlich überwacht und fließt in Echtzeit in die Autorisierungsentscheidung ein.

Um automatisierte Angriffe zu verhindern, werden Techniken wie Device Fingerprinting eingesetzt, um ein Gerät eindeutig zu identifizieren und an einen Benutzeraccount zu binden. Dies verhindert, dass gestohlene Zugangsdaten (wie Session-Cookies) auf fremden Geräten genutzt werden können, und ermöglicht eine präzisere Risikobewertung (Tank & Dalvi, 2018, S. 29).

Die Einbindung privater Endgeräte (Bring Your Own Device) stellt besondere Anforderungen an die Autorisierung, da hier die Balance zwischen Sicherheitskontrolle durch die Organisation und der Privatsphäre des Nutzers gewahrt werden muss (Miller et al., 2012, S. 54).

Die Verbindung mehrerer Faktoren erhöht die Resilienz gegenüber unbefugten Zugriffen, da Angreifer:innen nicht mehr nur ein einzelnes Geheimnis kompromittieren müssen. Dabei ist die erwähnte Unabhängigkeit der Faktoren und Bindung der Faktoren an Gerät und Nutzer:in entscheidend, wie sie in den Digital Identity Guidelines des NIST definiert sind (Temoshok et al., 2025, S. 12–14). Zu diesem Zweck wurden relevante Technologien und Protokolle kurz vorgestellt.

Als letztes soll auch die Kategorie Passwordless vorgestellt werden: Passwordlose Verfahren (Passwordless Login) ersetzen den Faktor „Wissen", also ein Passwort, durch Public-Key-Kryptografie und biometrische Verifikation. Moderne Standards wie FIDO2 oder Passkeys gelten als phishing-resistent und benutzerfreundlich, werden jedoch in der Praxis eher zögerlich implementiert (Lyastani et al., 2020, S. 270).

3.4 MFA und Regulatorik

Die Implementierung von Multifaktor-Authentifizierung ist in der modernen IT-Governance nicht mehr rein risikobasiert, sondern wird zunehmend durch regulatorische Vorgaben der Europäischen Union mandatiert. Insbesondere drei Rahmenwerke sind hierbei von zentraler Bedeutung: die NIS-2-Richtlinie, DORA und die DSGVO.

Die NIS- beziehungsweise NIS2-Richtlinie (Network and Information Security Directive) erweitert den Kreis der betroffenen Unternehmen („Essential" und „Important Entities") und

verschärft die Anforderungen an die Cybersicherheit. Da sich das Inkrafttreten der NIS-2 in Österreich noch verzögert, wird hier stattdessen die Lex specialis des Digital Operational Resilience Act (DORA) herangezogen. DORA zielt auf die digitale Widerstandsfähigkeit von Finanzunternehmen ab und schreibt strenge Anforderungen an (unter anderem) das IKT-Risikomanagement vor. Bezogen auf das Identitätsmanagement verlangt DORA robuste Authentifizierungsmechanismen, um den Zugriff auf IKT-Systeme und Daten zu schützen, wobei MFA als Standardmaßnahme gilt, um die Integrität von Finanztransaktionen und Kundendaten zu gewährleisten.

Auch die Datenschutz-Grundverordnung (kurz: DSGVO) wirkt als indirekter Treiber. Zwar nennt sie MFA nicht explizit, jedoch fordert Artikel 32 „geeignete technische und organisatorische Maßnahmen“, um ein dem Risiko angemessenes Schutzniveau zu gewährleisten. Aufsichtsbehörden und die ENISA interpretieren MFA heute als „Stand der Technik“ für den Zugriff auf sensible personenbezogene Daten, womit eine Nicht-Verwendung bei einem Data Breach als Verstoß gegen die DSGVO gewertet werden kann.

3.5 Verwendungskontext und Akzeptanz

Die Nutzung von MFA unterscheidet sich deutlich zwischen privaten und beruflichen Kontexten. Im privaten Bereich ist MFA häufig optional und wird vor allem dort schlagend, wo regulatorische Vorgaben bestehen – zum Beispiel im Online-Banking durch PSD2 (Govindraj C.V., 2024, S. 2). Dabei stehen persönliche Faktoren wie Bequemlichkeit und Datenschutzbedenken im Vordergrund. Im beruflichen Umfeld ist IT-Governance ein treibender Faktor für die Akzeptanz von MFA. Da Sicherheit oft nicht im Fokus der Nutzer:innen ist, erzwingt Governance die Nutzung, beispielsweise durch Richtlinien und technische Kontrollen (Das et al., 2020, S. 5).

In solchen Frameworks ist MFA meist verpflichtender Bestandteil eines Identity and Access Management (IAM) und dient der Einhaltung von Sicherheits- und Compliance-Standards (ISO 27001, NIST AAL2–3). Dabei erfordert ein Kompromiss zwischen Sicherheit und Benutzerfreundlichkeit sorgfältiges Vorgehen (Marky et al., 2022).

Zentrale Erfolgsfaktoren für die Akzeptanz von MFA-Systemen sind daher: Onboarding (Das et al., 2018, S. 6), risikobasierte Adaption der Systeme, Datenschutz und Fallback-Möglichkeiten.

Erstens intuitives Onboarding, denn eine verständliche Ersteinrichtung steigert die Akzeptanz gegenüber der Technologie (Colnago et al., 2018, S. 458–460). Zweitens minimiert die risikobasierte Authentifizierung zusätzlich Reibung, indem weitere Faktoren nur bei Bedarf, wie etwa verdächtigen Anmeldeversuchen, verlangt werden (Wiefling et al., 2019, S. 140). Drittens: Sichere Wiederherstellungsmechanismen – zum Beispiel Backup-Codes oder Hardware-Ersatz – sind notwendig, dürfen aber keine neuen Angriffsvektoren eröffnen (Klivan et al., 2023, S. 3140; Keil & Zugenmaier, 2024, S. 73). Und zuletzt: Datenschutzkonformität. Biometrische und kontextbasierte Verfahren müssen der DSGVO entsprechen (Zweckbindung, Einwilligung, Datensparsamkeit). Die Wahrnehmung von Privatsphäre beeinflusst die Akzeptanz erheblich (Malhotra et al., 2004, S. 340–341; Dienlin & Trepte, 2015, S. 285).

Eine strategische Einführung der Technologie mit Schulungen, klaren Kommunikationsmaßnahmen und definierten Recovery-Prozessen ist bei Cybersecurity und Governance generell für den Erfolg entscheidend (de Bruijn et al., 2017, S. 4).

4 Forschungsstand

4.1 Herausforderungen

4.1.1 MFA als technische Herausforderung

Die technische Implementierung von Multifaktor-Authentifizierung konfrontiert IT-Verantwortliche mit komplexen Herausforderungen, die weit über die bloße Auswahl eines zweiten Faktors hinausgehen. Der aktuelle Forschungsstand beschreibt ein Spannungsfeld, das von der Integration in bestehende Legacy-Architekturen über den Lifecycle der Token bis hin zur Absicherung der Recovery-Prozesse reicht.

Grundlegende Publikationen zu modernen Authentifizierungsmechanismen beschreiben diese Architekturen und definieren prinzipielle Anwendungsszenarien für unterschiedliche Sicherheitsniveaus (Ometov et al., 2018, S. 4). Ein besonderer Fokus liegt dabei auf der Ablösung unsicherer Verfahren: Konkrete Technologien wie FIDO-basierte Lösungen werden in der Literatur als vielversprechende, phishing-resistente Alternative zu klassischen OTP-Verfahren bewertet (Lyastani et al., 2020, S. 269). Ergänzend dazu widmen sich Reifegradanalysen der Frage, wie weit verbreitet diese Techniken in verschiedenen Branchen bereits sind und welche technischen Barrieren, wie fehlende Schnittstellen oder Legacy-Systeme, die Verwendung erschweren (Savaş et al., 2022, S. 2–4).

Spezifische Branchenanalysen zeigen, dass insbesondere im stark regulierten Finanzsektor hohe Hürden bestehen. Studien analysieren hier Implementierungsstrategien, die den Spagat zwischen strengen Compliance-Vorgaben und technischer Machbarkeit in heterogenen Banking-Umgebungen meistern müssen (Aburbeian & Fernández-Veiga, 2024, S. 178–180). Ein weiteres zentrales Forschungsfeld ist die geräteübergreifende Identitätsverwaltung. Arbeiten in diesem Bereich thematisieren, wie MFA konsistent und sicher in Bring-Your-Own-Device (BYOD)-Szenarien betrieben werden kann, ohne die Hoheit über die Unternehmensdaten zu verlieren (Hilbig et al., 2024, S. 74).

Ein häufig identifizierter kritischer Schwachpunkt sind die Account-Recovery-Mechanismen. Robuste und zugleich benutzerfreundliche Wiederherstellungsverfahren (zum Beispiel bei Token-Verlust) gelten als technisch schwer umzusetzen, da sie oft neue Angriffsvektoren für Social Engineering eröffnen (Keil & Zugenmaier, 2024, S. 73). Parallel dazu untersuchen aktuelle Arbeiten die Cloud-Integration von Identitätsdiensten (Identity-as-a-Service, IDaaS). Hierbei stehen Infrastruktur-, Datenschutz- und Verfügbarkeitsfragen im Vordergrund, die für die Resilienz cloudbasierter MFA-Angebote entscheidend sind (Otta et al., 2023, S. 4).

Abschließend widmet sich ein Teil der Forschung der Evolution der Faktoren selbst. Arbeiten zur Biometrie beleuchten deren Rolle als komfortabler, aber datenschutzrechtlich sensibler Bestandteil von MFA-Szenarien (Wolf et al., 2019, S. 151; Trewin et al., 2012, S. 159).

Darüber hinaus untersuchen Beiträge auch experimentelle Authentifikationsformen, etwa auf Basis von Schallwellen, Bewegungs- oder Geräuschmustern. Diese liefern Hinweise auf alternative Faktoren für spezifische Nischenanwendungen, befinden sich jedoch meist noch im Stadium experimenteller Prototypen (Karapanos et al., 2015, S. 483).

4.1.2 MFA als Herausforderung an Nutzer:innen

Zusätzlich zu den vorgestellten, technischen Fragestellungen konzentrieren sich einige Publikationen auf die Perspektive der Nutzenden. Aspekte wie Akzeptanz und Benutzerfreundlichkeit entscheiden mit über die tatsächliche Sicherheit von MFA-Systemen. Studien zur Awareness von Nutzenden zeigen, dass mangelndes Verständnis für Funktionsweise und Grund der Anwendung zu seltener Nutzung oder Umgehungsverhalten führt (Acemyan et al., 2018). Weitere Untersuchungen und Feldstudien beleuchten die Verbreitung und Wahrnehmung von FIDO-Technologien in konkreten Kontexten, beispielsweise in Deutschland, und liefern Hinweise auf Blockaden und Treiber für die Verwendung (Keil & Zugenmaier, 2024, S. 76f).

Historische Betrachtungen des Übergangs zu verpflichtender 2FA in bestimmten Sektoren zeigen, wie regulatorische Vorgaben und Compliance-Anforderungen Adoptionstreiber sein können (Wibowo & Ramli, 2022, S. 2). Zugleich können erweiterte beziehungsweise neue Vorgaben aber auch Usability-Probleme und Supportaufwände erhöhen (Petsas et al., 2015). Usability-Analysen spezifisch zu Hardware-Security-Keys und FIDO-Keys untersuchen Aspekte wie Setup-Komplexität, Fehlerquoten und subjektive Zufriedenheit und kommen zu dem Schluss, dass physische Keys zwar hohe Sicherheit liefern, aber in Teilen der Nutzerpopulation auf Akzeptanzhürden stoßen (Ciolino et al., 2019; Reynolds et al., 2018).

Weitere empirische Arbeiten adressieren soziale Determinanten und Kontextfaktoren der Akzeptanz: Einflussgrößen beziehungsweise demographische Variablen wie Geschlecht oder Alter wurden in mehreren Studien untersucht (Gratian et al., 2018, S. 349f), wobei heterogene Ergebnisse darauf hindeuten, dass Akzeptanz individuell erklärbar ist und kontextuelle Faktoren (zum Beispiel Anwendungsszenario, Schulung, Vorerfahrungen) eine große Rolle spielen (Anwar et al., 2017). Feldstudien an Hochschulen und in Organisationen liefern zusätzliche Einsichten in Adoptionserfahrungen, typische Barrieren sowie praktikable Maßnahmen zur Steigerung der Nutzerakzeptanz (Colnago et al., 2018; Dutson et al., 2019). Mehrere Analysen, warum Nutzer:innen MFA nicht akzeptieren oder umgehen, fassen häufig Gründe wie wahrgenommene Komplexität, fehlende Nutzenwahrnehmung und schlechte Recovery-Erfahrungen zusammen (Pearman et al., 2019). Gleichzeitig wurden MFA-Systeme in Studien als ein Zeichen von Sicherheit erlebt. So beschreiben beispielsweise Krol et al. (2015, S. 2), dass mehrere Teilnehmende ihrer Studie die zusätzliche Sicherheit bei Banking-Anwendungen schätzen.

4.1.3 MFA als IT-Governance-Herausforderung

Die vorgestellte Literatur verdeutlicht, dass die Einführung und Verwendung von Authentifizierungsmechanismen auch eine Governance-Aufgabe ist. Governance umfasst in diesem

Kontext die strategische Steuerung, Regulierung und Überwachung von Prozessen innerhalb von Organisationen (Savaş et al., 2022).

Studien zu Governance-Modellen in Bezug auf Sicherheit zeigen, dass Reifegrad, Verantwortlichkeiten und Kommunikation für die nachhaltige Wirksamkeit von MFA-Systemen wichtig sind (Wibowo et al., 2022, S. 4–6). Unternehmen mit klar definierten Policies und kontinuierlichem Monitoring erreichen nachweislich höhere Sicherheits- und Akzeptanzwerte (Krykavska, 2023, S. 7).

IT-Governance-Frameworks wie die ISO 27001 oder die NIST Digital Identity Guidelines (Temoshok et al., 2025) machen diese Steuerung anwendbar, indem sie notwendige Authenticator-Assurance-Levels (AAL) und Anforderungen an die Technologien festlegen. Auf regulatorischer Ebene verpflichten PSD2 und eIDAS Organisationen zur Nutzung starker Authentifizierung, was Governance-Strukturen erforderlich macht, die technische und rechtliche Vorgaben integrieren (Govindraj C.V., 2024, S. 4).

Im öffentlichen Sektor rückt damit die Frage nach digitaler Souveränität und Vertrauensinfrastruktur in den Vordergrund: Studien zu E-Government-Governance betonen, dass nachhaltige Sicherheitsstrategien nur durch ein Zusammenspiel von technischen Standards, institutioneller Verantwortung und nutzer:innenzentrierter Politik erreicht werden können (Ariyadi & Akbar, 2025, S. 2).

In Unternehmenskontexten treten zusätzliche organisatorische Herausforderungen auf: Vendor Lock-in, Cloud-Abhängigkeiten, Helpdesk-Aufwand bei Tokenverlust oder vergessenem Passwort und organisatorische Integrationsprobleme in bestehende IAM-Strukturen (Das et al., o. J., S. 4–6; Temoshok et al., 2025, §5).

Eine konkrete Herausforderung sind auch informelle Systeme zur Umgehung, die sogenannte Schatten/Shadow-IT, die häufig als Antwort auf Governance-Vorschriften entsteht (Fagan & Khan, 2016, S. 65–67).

Aktuelle regulatorische Entwicklungen wie die NIS2-Richtlinie verstärken außerdem die Anforderungen an die organisationalen Nachweispflichten und das Management kritischer Dienste immer weiter. Entsprechende Analysen zu NIS2 sind für die Ausgestaltung von MFA-Governance empfehlenswert (Barton & Lewis, 2024). Ebenso sollten neuere Arbeiten zur Lieferketten- und Vendor-Governance in MFA-Kontexten (zum Beispiel Lassak et al., 2024) berücksichtigt werden, da Third-Party-Provider und Cloud-Identitätsdienste zentrale Risiken und Abhängigkeiten mit sich bringen.

Aus Governance-Sicht erfordert die erfolgreiche Implementierung von MFA sowohl technische Kompetenz, wie auch klare Zuständigkeiten und Awareness-Programme beziehungsweise Schulung (de Bruijn et al., 2017, S. 2).

4.2 Wirkmechanismen der Nutzung von MFA

Die Analyse der Literatur zeigt, dass IT-Governance nicht isoliert im Unternehmenskontext wirkt, sondern als Katalysator für privates Sicherheitsverhalten fungiert. Konkret lassen sich drei Wirkmechanismen identifizieren:

Erstens der Kompetenz-Transfer: Die größte Hürde für private MFA-Nutzung ist oft nicht der Widerwille, sondern die technische Unsicherheit. Strenge Governance-Richtlinien im

Beruf zwingen Nutzer:innen, diese Hürde zu überwinden. Studien wie die von Colnago et al. (2018) bestätigen diesen Lerneffekt: User:innen, die Usability von MFA-Token im „Safe Space“ des Unternehmens (mit Support-Netz) kennenlernen, trauen sich deren Anwendung auch privat zu. Governance wirkt hier somit sozusagen als unfreiwilliges Schulungsprogramm.

Zweitens die unterschiedliche Risikowahrnehmung (Awareness): Während private Nutzer:innen Risiken oft abstrakt einschätzen, wird Risikomanagement in Unternehmen konkretisiert. Richtlinien, die auf NIS-2 oder DSGVO basieren, kommunizieren intern wie extern explizit, warum was geschützt wird. Diese Sensibilisierung schwappt über: Das Verständnis, dass Identitäten und Daten schützenswert sind, bleibt nach Feierabend bestehen (Spillover). Governance verändert MFA somit von einer „lästigen Schikane“ zu einem „notwendigen Standard“.

Drittens der persönliche Widerstand bzw. Reaktivität: Mehrere Quellen zeigten auch eine negative Auswirkung von Governance. Ist die Governance zu starr und die Usability schlecht (zum Beispiel häufige Re-Authentifizierung ohne biometrische Optionen), entsteht „Security Fatigue“ (Ermüdung). Dies führt nicht zu privater Adoption, sondern zu einer Abwehrhaltung. Nutzer:innen vermeiden privat Sicherheitsmaßnahmen, um ihre „kognitive Ruhe“ zu beschützen.

4.3 IT-Governance als Treiber der Akzeptanz und Nutzung von Multifaktor-Authentifizierung

Die vorgestellten Quellen bestätigen also zusammenfassend das Zusammenspiel zwischen dem durch IT-Governance gesteuerten, beruflichen Umfeld, und dem von Usability und persönlicher Wahrnehmung geprägten privaten Kontext.

Studien zu Governance-Modellen im Bereich IT-Sicherheit zeigen, dass Reifegrad, klar definierte Verantwortlichkeiten und transparente Kommunikationsstrukturen entscheidend für die nachhaltige Wirksamkeit von MFA-Systemen sind (Wibowo et al., 2022, S. 4–6). Organisationen, die über klar formulierte Policies, standardisierte Prozesse und ein kontinuierliches Monitoring verfügen, erreichen nachweislich nicht nur höhere Sicherheitsstandards, sondern auch eine bessere Nutzer:innenakzeptanz.

IT-Governance-Frameworks wie die ISO 27001 oder die NIST Digital Identity Guidelines (Temoshok et al., 2025) stellen Instrumente bereit, mit denen Organisationen Sicherheitsmaßnahmen systematisch planen, steuern und evaluieren können. Sie legen unter anderem Authenticator-Assurance-Levels (AAL) fest, die die Anforderungen an die Stärke der Authentifizierung definieren, und geben technische Spezifikationen vor, die die Implementierung von MFA erleichtern. Diese Frameworks unterstützen Organisationen dabei, die Balance zwischen Sicherheit, Benutzerfreundlichkeit und regulatorischer Compliance zu halten.

Auf regulatorischer Ebene verpflichten Vorgaben wie PSD2 und eIDAS Unternehmen zur Nutzung starker Authentifizierung. Dies erfordert Governance-Strukturen, die technische, organisatorische und rechtliche Anforderungen integrieren, um sowohl interne Sicherheitsziele als auch externe Vorschriften zu erfüllen (Govindraj C.V., 2024; Krykavska, 2023). Die Ein-

haltung solcher regulatorischen Anforderungen ist insbesondere in hochsensiblen Branchen wie Finanzwesen oder öffentlicher Verwaltung kritisch, da Verstöße erhebliche rechtliche Konsequenzen und Vertrauensverluste nach sich ziehen können.

Im öffentlichen Sektor gewinnt zudem die digitale Souveränität an Bedeutung: E-Government-Initiativen erfordern sichere und vertrauenswürdige Infrastrukturen, die den Schutz sensibler Bürgerdaten gewährleisten. Studien zu E-Government-Governance betonen, dass nachhaltige Sicherheitsstrategien nur durch ein Zusammenspiel von technischen Standards, institutioneller Verantwortung und nutzerzentrierter Politik erreicht werden können (Ariyadi & Akbar, 2025, S. 2).

Es gibt Hinweise auf einen sogenannten Spill-over-Effekt wie ihn Staines (1980) in einem arbeitspsychologischen Kontext beschrieb (Staines, 1980, S. 120–121). Konkret insofern, dass positive Erfahrungen mit gut implementierter MFA im beruflichen Kontext (beispielsweise durch erfolgreiche IT-Governance) dazu führen können, dass Nutzer:innen MFA auch privat aktivieren. Nutzende, die im beruflichen Kontext gute Erfahrungen mit einer MFA-Lösung (wie Push-Benachrichtigungen) gemacht haben, neigen eher dazu, diese Technologien auch für private Accounts zu aktivieren (Colnago et al., 2018, S. 2).

Umgekehrt führen negative Erfahrungen oder mangelndes Verständnis von Risiken dazu, dass Nutzende MFA-Technologie privat ablehnen, weil sie glauben, ihre privaten Daten seien weniger wichtig. Wenn Nutzer:innen im beruflichen Kontext beispielsweise negative Erfahrungen machen, sinkt die Akzeptanz. Krol et al. (2015, S. 3) stellten fest, dass Kund:innen im privaten Banking sogar den Finanzdienstleister wechselten, weil sie umständliche MFA-Hardware vermeiden wollten. Nutzende, welche negative Konsequenzen erleben, raten anderen aktiv von der Nutzung ab und beeinflussen so ihr Umfeld mit (Das et al., 2020, S. 2).

4.4 Beantwortung der Forschungsfrage

Die vorliegende Arbeit untersucht das Spannungsfeld zwischen beruflicher Pflicht und privater Freiwilligkeit bei der Nutzung von Multifaktor-Authentifizierung. Ziel ist es, den Einfluss von IT-Governance auf dieses Nutzungsverhalten zu analysieren. Dabei soll folgende Forschungsfrage beantwortet werden: Inwiefern wirkt IT-Governance als Treiberin für die Akzeptanz und Nutzung von Multifaktor-Authentifizierung im Vergleich zwischen beruflichen und privaten Kontexten? Die Untersuchung zeigt deutlich, dass IT-Governance über die Unternehmensgrenzen hinaus wirksam ist. Sie tritt als treibender Faktor auf, um die Brücke zwischen notwendiger Sicherheit und gewünschter Bequemlichkeit (Usability) zu schlagen. Während im privaten Kontext oft die Bequemlichkeit vorrangig ist und MFA häufig als Störfaktor wahrgenommen wird, etabliert Governance im beruflichen Kontext – getrieben durch Regulatorien wie NIS-2 und DORA – ein dichtes Netz aus Vorgaben, die sich nicht mit dieser gefühlten Bequemlichkeit umgehen lassen. Bezüglich der Frage, wie IT-Governance die Verwendung beeinflusst, lässt sich feststellen: IT-Governance wirkt als Enabler, Ermöglicherin. Durch die verpflichtende Nutzung in professionellen Kontexten erwerben Anwender:innen notwendige technische Kompetenz, die ihnen privat oft fehlt. Dieser „Spill-over-Effekt“ führt dazu, dass berufliche Sicherheitsstandards in das Privatleben übernommen werden. Aller-

dings zeigt sich auch, dass schlechte Implementierung oder unbequeme Tools zu Widerstand führen, wodurch Governance kontraproduktiv auf die Nutzung wirken kann. Für die Praxis bedeutet das schlussendlich, dass Unternehmen ihre Verantwortung neu definieren müssen. IT-Governance ist einerseits ein Werkzeug zur Risikominimierung in der eigenen Infrastruktur, aber auch weiters ein Instrument zur Förderung der allgemeinen digitalen Resilienz der Mitarbeitenden. Zukünftige Forschung könnte diesen Zusammenhang quantitativ prüfen, um zu messen, wie stark der Zusammenhang zwischen beruflichem Zwang zur Sicherheit und privater Sicherheitskompetenz tatsächlich ist.

5 Forschungsmethodik

5.1 Forschungsdesign und wissenschaftstheoretische Einordnung

Die vorliegende Arbeit basiert auf einem quantitativen Forschungsdesign, welches deduktiv ausgerichtet ist. Die methodologische Verortung erfolgt im Paradigma des Kritischen Rationalismus nach Karl Popper. Gemäß diesem Ansatz kann wissenschaftlicher Fortschritt nur durch Falsifikation erzielt werden. Dementsprechend wurden aus der bestehenden Literatur (Usability-Forschung, IT-Governance, Spill-over-Theorie) theoriegeleitete Hypothesen abgeleitet, die empirisch überprüft werden, um die Nullhypothese (H_0) zu verwerfen.

Für die Beantwortung der Forschungsfrage – inwiefern IT-Governance als Einflussfaktor auf die private Verwendung von Multifaktor-Authentifizierung (MFA) wirkt – ist ein quantitativer Ansatz zwingend erforderlich. Es gilt, die Stärke und Richtung der Zusammenhänge zwischen der beruflichen MFA-Nutzung, der wahrgenommenen Usability, den Governance-Vorgaben und dem privaten Sicherheitsverhalten zu messen. Während qualitative Methoden tiefere Einblicke in individuelle Motive bieten könnten, erlaubt erst die standardisierte quantitative Erhebung generalisierbare Aussagen über Kausalitäts-Tendenzen und signifikante Korrelationen in der breiten Masse der Erwerbstätigen. Der primäre Fokus der Untersuchung liegt dabei auf der Schnittstelle zwischen Arbeitswelt und Privatleben (Work-Life-Interface bzw. Security Spill-over).

5.2 Grundgesamtheit und Stichprobenziehung

Um eine hohe Validität der Ergebnisse zu gewährleisten, muss die Zielgruppe präzise eingegrenzt werden. Die Grundgesamtheit der vorliegenden Untersuchung bilden **erwerbstätige Personen im DACH-Raum, die im Rahmen ihrer beruflichen Tätigkeit regelmäßig mit IT-Systemen und digitalen Authentifizierungsverfahren konfrontiert sind**.

Die Rekrutierung der Probanden erfolgt über eine Gelegenheitsstichprobe (Convenience Sampling). Die Distribution des Online-Fragebogens wird primär über berufliche Netzwerke (wie LinkedIn und Xing) sowie private Kommunikationskanäle durchgeführt. Diese Methode ermöglicht eine effiziente und breite Streuung. Im Rahmen der Erhebung wird streng auf die Einhaltung der Datenschutz-Grundverordnung (DSGVO) geachtet. Zu Beginn der Umfrage werden die Teilnehmenden über die Freiwilligkeit, den Zweck der Studie sowie die vollständig

anonyme und aggregierte Speicherung der Daten aufgeklärt, was insbesondere bei dem sensiblen Thema IT-Sicherheit unabdingbar ist, um sozial erwünschtes Antwortverhalten zu minimieren.

5.3 Datenerhebung und Instrumente

Die Primärdatenerhebung erfolgt mittels einer standardisierten Online-Befragung über das Tool *Microsoft Forms*. Diese Methode bietet den Vorteil der Ortsunabhängigkeit, einer leichten Skalierbarkeit sowie einer effizienten digitalen Weiterverarbeitung der Daten.

5.3.1 Fragebogenkonstruktion

Der Fragebogen wurde entlang eines klaren dramaturgischen Aufbaus konzipiert: Nach der Einleitung und Klärung des Datenschutzes werden zunächst demografische Daten (Alter, Branche, IT-Affinität) erhoben. Anschließend folgen Fragen zum beruflichen Kontext (Governance-Vorgaben), zum privaten Status Quo der MFA-Nutzung sowie abschließend zur Usability-Bewertung.

Die Formulierung der Items orientiert sich strikt an den methodischen Vorgaben der empirischen Sozialforschung, insbesondere den „10 Geboten der Frageformulierung“ nach Porst (2014). Um Verzerrungen zu vermeiden, wurde explizit auf Suggestivfragen, doppelte Verneinungen sowie zu komplexe Satzstrukturen, die zu einer kognitiven Überforderung der Teilnehmenden führen könnten, verzichtet. Die Erfassung der Einstellungen und Wahrnehmungen erfolgt primär über geschlossene Fragen sowie 5-stufige Likert-Skalen (von „stimme gar nicht zu“ bis „stimme voll zu“).

5.3.2 Operationalisierung der Variablen

Um die theoretischen Konstrukte messbar zu machen, wurden sie wie folgt operationalisiert:

- **Abhängige Variable (Private MFA-Nutzung):** Gemessen über die Nutzungshäufigkeit und die Art der privat abgesicherten Dienste (z. B. Social Media, Banking, E-Mail).
- **Unabhängige Variable 1 (IT-Governance):** Gemessen über den wahrgenommenen Druck, die Verbindlichkeit von Richtlinien (Compliance) und die Unterstützung durch den Arbeitgeber (z. B. Schulungen, Support).
- **Unabhängige Variable 2 (Usability):** Gemessen über die wahrgenommene Einfachheit der Bedienung und die kognitive Last, in Anlehnung an etablierte Skalen wie die System Usability Scale (SUS).
- **Unabhängige Variable 3 (Spill-over-Effekt):** Gemessen über Items, die eine psychologische Übertragung von beruflichen Gewohnheiten ins Privatleben abfragen (z. B. „Weil ich MFA im Büro nutze, habe ich es auch privat aktiviert“).

5.3.3 Pre-Test

Vor der finalen Feldphase wurde der Fragebogen einem Pre-Test mit einer kleinen Stichprobe ($n = 5$) unterzogen. Ziel war es, die technische Funktionalität, die Dauer der Bearbeitung sowie die semantische Verständlichkeit der Items zu prüfen. Basierend auf dem Feedback wurden kleinere sprachliche Unschärfen bereinigt, um die Validität des Messinstruments zu sichern.

5.4 Datenaufbereitung und Auswertungsverfahren

Die Datenanalyse erfolgt mit der Open-Source-Software *Orange Data Mining*. Die Wahl fiel auf dieses Tool, da es durch seine visuelle Programmierung eine transparente, reproduzierbare und nachvollziehbare Kombination aus Datenbereinigung, explorativer Datenanalyse und inferenzstatistischer Testung innerhalb einer Workflow-Umgebung ermöglicht. Der gesamte Analyseprozess wurde als Orange-Workflow (`.ows`) dokumentiert.

5.4.1 Data Preprocessing (Datenbereinigung)

Über das *File Widget* werden die Rohdaten importiert. Im Rahmen der Datenvorverarbeitung werden unvollständige Datensätze ausgeschlossen (*Data Cleaning*). Über die *Feature Selection* und *Edit Domain* werden die Variablentypen definiert (Ordinal für Likert-Skalen, Nominell für demografische Merkmale). Zudem werden Ausreißer (z. B. „Speed-Speeder“ mit unrealistisch kurzen Bearbeitungszeiten) herausgefiltert.

5.4.2 Deskriptive und Inferenzstatistische Analyse

Die **deskriptive Statistik** dient der Darstellung der Stichprobenverteilung. Mittels des *Distributions Widgets* (Histogramme) werden soziodemografische Daten und allgemeine MFA-Nutzungshäufigkeiten visualisiert. *Box Plots* kommen zum Einsatz, um Unterschiede in der Usability-Bewertung zwischen verschiedenen Nutzergruppen (z. B. hohe vs. niedrige IT-Affinität) visuell zu prüfen.

Zur Überprüfung der aufgestellten Hypothesen kommt die **Inferenzstatistik** zum Einsatz:

- Zur Prüfung von H_2 **(Usability)** und H_3 **(Spill-over-Effekt)** wird eine Korrelationsanalyse über das *Correlation Widget* durchgeführt. Da Likert-Skalen methodisch meist als ordinalskaliert betrachtet werden, wird der Rangkorrelationskoeffizient nach Spearman (ρ) berechnet. Flankierend werden *Scatter Plots* genutzt, um die Zusammenhänge visuell zu verifizieren.

- Zur Prüfung von H_1 **(Einfluss der IT-Governance)** werden Gruppenvergleiche durchgeführt. Über das *ANOVA* bzw. *t-Test Widget* (bzw. bei Verletzung der Normalverteilungsannahme der Mann-Whitney-U-Test) wird getestet, ob sich das private MFA-Nutzungsverhalten von Personen mit strenger beruflicher Governance signifikant von Personen ohne entsprechende berufliche Vorgaben unterscheidet.

Die Signifikanzschwelle wird auf $\alpha = 0.05$ festgelegt. Alle Ergebnisse werden in einem ausführlichen Analysebericht dokumentiert, der die statistischen Kennzahlen, die Effektstärken sowie die Interpretation der Befunde im Kontext der Forschungsfrage enthält.

5.5 Ethische Überlegungen

Die Durchführung der Studie erfolgt unter strikter Einhaltung ethischer Richtlinien. Alle Teilnehm enden werden vorab über die Ziele der Forschung, die Freiwilligkeit der Teilnahme sowie die Anonymität und Vertraulichkeit der Daten informiert. Es wird sichergestellt, dass keine personenbezogenen Daten erhoben werden, die Rückschlüsse auf die Identität der Probanden zulassen. Zudem wird die Möglichkeit gegeben, die Teilnahme jederzeit ohne Angabe von Gründen abzubrechen. Die gewonnenen Erkenntnisse werden ausschließlich für wissenschaftliche Zwecke verwendet und in aggregierter Form veröffentlicht, um die Privatsphäre der Teilnehmenden zu schützen.

6 Zusammenfassung

Die vorliegende Arbeit hat gezeigt, dass die technische Sicherheit von Multifaktor-Authentifizierung allein nicht ausreicht, um eine flächendeckende Nutzung zu gewährleisten. Vielmehr hängt ihre Wirksamkeit maßgeblich von der Benutzbarkeit und der Akzeptanz der Anwender:innen ab. Wie die Literaturanalyse verdeutlichte, wird MFA von Nutzer:innen häufig als Störfaktor im Arbeitsfluss oder als zeitraubend wahrgenommen. Insbesondere im privaten Kontext, wo Nutzer:innen bei technischen Problemen auf sich allein gestellt sind, Risiken nur diffus wahrnehmen, und kein institutioneller Druck besteht, führt diese wahrgenommene Hürde oft zur Umgehung von Sicherheitsmechanismen. In diesem Spannungsfeld tritt IT-Governance als entscheidende Treiberin auf. Im beruflichen Umfeld ersetzt sie die oft fehlende intrinsische Motivation durch regulatorische Notwendigkeit. In der Literaturbetrachtung zeigt sich, dass Governance hier eine Doppelfunktion erfüllt: Einerseits erzwingt sie die Nutzung durch Richtlinien und technische Kontrollen. Andererseits unterstützt sie diesen Zwang durch Support-Strukturen (zum Beispiel Helpdesk, Schulung). Diese senken die Hürden bei der Einrichtung und erleichtern die Fehlerbehebung, und sind im privaten Kontext meistens nicht vorhanden. Ein zentrales Ergebnis dieser Arbeit ist die Beschreibung des sogenannten „Spill-over-Effekts“ als Bindeglied zwischen beruflichen und privaten Kontexten. Die betrachteten Forschungsdokumente legen nahe, dass die verpflichtende Nutzung in beruflichen Kontexten auch die Akzeptanz im privaten Kontext fördern kann. Indem Nutzer:innen im geschützten Unternehmensumfeld Kompetenzen aufbauen und die Verwendung von Technologie normalisieren, sinkt die Hemmschwelle, diese auch privat einzusetzen. Die zentrale Forschungsfrage, wie IT-Governance die Verwendung von MFA beeinflusst, lässt sich somit beantworten: IT-Governance wirkt als Katalysator sowohl durch Supportmaßnahme wie zur Sensibilisierung. Indem Governance im Beruf technische Standards durchsetzt und dafür sensibilisiert, wirkt sie auch in anderen Kontexten, also über Unternehmensgrenzen hinaus und leistet indirekt einen Beitrag zur Erhöhung der privaten Sicherheitskompetenz der Mitarbeitenden.

7 Zusammenfassung

Die vorliegende Arbeit hat gezeigt, dass die technische Sicherheit von Multifaktor-Authentifizierung allein nicht ausreicht, um eine flächendeckende Nutzung zu gewährleisten. Vielmehr hängt ihre Wirksamkeit maßgeblich von der Benutzbarkeit und der Akzeptanz der Anwender:innen ab. Wie die Literaturanalyse verdeutlichte, wird MFA von Nutzer:innen häufig als Störfaktor im Arbeitsfluss oder als zeitraubend wahrgenommen. Insbesondere im privaten Kontext, wo Nutzer:innen bei technischen Problemen auf sich allein gestellt sind, Risiken nur diffus wahrnehmen, und kein institutioneller Druck besteht, führt diese wahrgenommene Hürde oft zur Umgehung von Sicherheitsmechanismen. In diesem Spannungsfeld tritt IT-Governance als entscheidende Treiberin auf. Im beruflichen Umfeld ersetzt sie die oft fehlende intrinsische Motivation durch regulatorische Notwendigkeit. In der Literaturbetrachtung zeigt sich, dass Governance hier eine Doppelfunktion erfüllt: Einerseits erzwingt sie die Nutzung durch Richtlinien und technische Kontrollen. Andererseits unterstützt sie diesen Zwang durch Support-Strukturen (zum Beispiel Helpdesk, Schulung). Diese senken die Hürden bei der Einrichtung und erleichtern die Fehlerbehebung, und sind im privaten Kontext meistens nicht vorhanden. Ein zentrales Ergebnis dieser Arbeit ist die Beschreibung des sogenannten „Spill-over-Effekts“ als Bindeglied zwischen beruflichen und privaten Kontexten. Die betrachteten Forschungsdokumente legen nahe, dass die verpflichtende Nutzung in beruflichen Kontexten auch die Akzeptanz im privaten Kontext fördern kann. Indem Nutzer:innen im geschützten Unternehmensumfeld Kompetenzen aufbauen und die Verwendung von Technologie normalisieren, sinkt die Hemmschwelle, diese auch privat einzusetzen. Die zentrale Forschungsfrage, wie IT-Governance die Verwendung von MFA beeinflusst, lässt sich somit beantworten: IT-Governance wirkt als Katalysator sowohl durch Supportmaßnahme wie zur Sensibilisierung. Indem Governance im Beruf technische Standards durchsetzt und dafür sensibilisiert, wirkt sie auch in anderen Kontexten, also über Unternehmensgrenzen hinaus und leistet indirekt einen Beitrag zur Erhöhung der privaten Sicherheitskompetenz der Mitarbeitenden.

8 Anhang